NORDWIND LOGISTICS GMBH

Informationssicherheitsleitlinie

Leitlinie zur Informationssicherheit der Nordwind Logistics GmbH – lokale Fassung für die Standorte in Österreich, Deutschland und Tschechien –

Dokumenten-ID	NWL-ISMS-POL-001
Version	3.2 (FINAL)
Stand	15.02.2025
Gültig ab	01.03.2025
Klassifizierung	INTERN
Dokumentenverantwortlicher	DI Markus Pichler, Informationssicherheitsbeauftragter (ISB)
Freigabe	Geschäftsführung (Mag. Bernhard Strasser, Ing. Petra Lindner)

Dieses Dokument ersetzt alle vorherigen Versionen. Ausgedruckte Exemplare unterliegen nicht dem Änderungsdienst.

Inhaltsverzeichnis

1 Zweck dieser Leitlinie . . . 4

2 Geltungsbereich . . . 4

2.1 Organisatorischer Geltungsbereich . . . 4

2.2 Personeller Geltungsbereich . . . 4

2.3 Verhältnis zu Konzernvorgaben . . . 4

3 Informationssicherheitsziele . . . 4

3.1 Schutzziele . . . 4

3.2 Konkrete Ziele . . . 4

3.3 Einstufung nach NIS-2 . . . 5

4 Organisation der Informationssicherheit . . . 5

4.1 Geschäftsführung . . . 5

4.2 Informationssicherheitsbeauftragter (ISB) . . . 5

4.3 Informationssicherheitsteam (IST) . . . 5

4.4 Systemowner . . . 5

4.5 Führungskräfte und Mitarbeitende . . . 5

5 Grundsätze . . . 5

5.1 Klassifizierung von Informationen . . . 5

5.2 Risikomanagement . . . 5

5.3 Zugriffsrechte . . . 5

5.4 Business Continuity . . . 6

5.5 Lieferanten und Dienstleister . . . 6

5.6 Sensibilisierung . . . 6

5.7 Behandlung von Sicherheitsvorfällen . . . 6

6 Ausnahmen und Verstöße . . . 6

6.1 Ausnahmen . . . 6

6.2 Verstöße . . . 6

7 Überprüfung und Weiterentwicklung . . . 6

8 Inkrafttreten . . . 6

Versionshistorie

Version	Datum	Autor	Änderung
1.0	12.04.2019	T. Gruber	Erstfassung
2.0	03.09.2021	T. Gruber	Überarbeitung nach Zertifizierungsaudit; Aufnahme der Niederlassung České Budějovice

Version	Datum	Autor	Änderung
3.0	30.06.2023	M. Pichler	Anpassung an ISO/IEC 27001:2022, neue Rollenbeschreibung (Kap. 4)
3.1	14.11.2024	M. Pichler	Ergänzung NIS-2, Verweis auf IR-Richtlinie
3.2	15.02.2025	M. Pichler	Redaktionelle Änderungen, Freigabe durch die Geschäftsführung

1 Zweck dieser Leitlinie

Die Nordwind Logistics GmbH (im Folgenden „Nordwind“ oder „das Unternehmen“) erbringt Speditions-, Transport- und Lagerlogistikleistungen für Kunden aus Industrie, Handel und E-Commerce. Unsere Geschäftsprozesse – von der Auftragsannahme über die Disposition bis zur Kommissionierung im Lager und zur Zustellung beim Empfänger – hängen in hohem Maß von funktionierenden IT-Systemen ab, insbesondere vom Lagerverwaltungssystem (LVS „Kranich“), dem Transport-Management-System (TMS) und der Telematikplattform. Ein Ausfall dieser Systeme führt binnen weniger Stunden zu Lieferverzug, Vertragsstrafen und Reputationsschäden.

Diese Leitlinie beschreibt den Stellenwert der Informationssicherheit für Nordwind, die übergeordneten Sicherheitsziele sowie die grundlegende Organisation des Informationssicherheits-Managementsystems (ISMS). Sie ist das oberste Dokument der lokalen ISMS-Dokumentenpyramide; alle weiteren Richtlinien, Konzepte und Arbeitsanweisungen bauen darauf auf.

2 Geltungsbereich

2.1 Organisatorischer Geltungsbereich

Die Leitlinie gilt für alle Standorte der Nordwind Logistics GmbH:

- Österreich: Linz (Zentrale und Zentrallager Linz-Hafen), Wels (Lager und Ausweich-Rechenzentrum), Wien-Inzersdorf (Umschlaglager)
- Deutschland: Passau, Nürnberg
- Tschechien: České Budějovice (Niederlassung)

2.2 Personeller Geltungsbereich

Sie gilt für alle Mitarbeitenden, Leiharbeitskräfte und Praktikant:innen sowie für externe Personen (Dienstleister, Subunternehmer, Frachtführer), die Zugang zu Informationen oder IT-Systemen von Nordwind erhalten. Externe werden vertraglich zur Einhaltung verpflichtet.

2.3 Verhältnis zu Konzernvorgaben

Nordwind ist eine 100-%-Tochter der Nordwind Group B.V. (Venlo, Niederlande). Die Group Information Security Policies und Standards des Konzerns (in englischer Sprache, z. B. GIS-STD-07 *Cryptography Standard* oder NWG-POL-CLD-004 *Cloud Security Policy*) gelten unmittelbar. Lokale Richtlinien konkretisieren die Konzernvorgaben; sie dürfen strenger, aber nicht schwächer sein. Bei Widersprüchen zwischen Konzern- und lokalen Vorgaben gilt die jeweils strengere Regelung; Zweifelsfälle klärt der ISB mit dem Group Security Office.

3 Informationssicherheitsziele

3.1 Schutzziele

Informationen und IT-Systeme sind entsprechend ihrem Schutzbedarf hinsichtlich **Vertraulichkeit**, **Integrität** und **Verfügbarkeit** zu schützen. Ergänzend achten wir auf Authentizität und Nachvollziehbarkeit von Transaktionen, z. B. bei Bestandsbuchungen und Zustellnachweisen.

3.2 Konkrete Ziele

- Verfügbarkeit der logistikkritischen Systeme (LVS, TMS, Telematik) entsprechend den in den Notfallplänen festgelegten Wiederanlaufzeiten
- Schutz der Kunden- und Sendungsdaten vor unbefugtem Zugriff und Missbrauch
- Einhaltung gesetzlicher und vertraglicher Anforderungen (u. a. DSGVO, NIS-2, Zollvorschriften, Kundenverträge mit Sicherheitsanforderungen)

- Aufrechterhaltung der Zertifizierung nach ISO/IEC 27001 für den Standort Linz (zertifiziert seit 2020); Ausweitung auf alle Standorte bis Ende 2026
- Sensibilisierung aller Mitarbeitenden einschließlich der Fahrerinnen und Fahrer

3.3 Einstufung nach NIS-2

Nordwind ist als „wichtige Einrichtung“ im Sinne der Richtlinie (EU) 2022/2555 (NIS-2) eingestuft. Daraus ergeben sich insbesondere Pflichten zum Risikomanagement, zur Schulung der Geschäftsleitung sowie Meldepflichten bei erheblichen Sicherheitsvorfällen. Das Meldeverfahren ist in der Richtlinie Incident Response und NIS-2-Meldeverfahren geregelt.

4 Organisation der Informationssicherheit

4.1 Geschäftsführung

Die Geschäftsführung trägt die Gesamtverantwortung für die Informationssicherheit. Sie genehmigt diese Leitlinie, stellt die erforderlichen Ressourcen bereit, nimmt jährlich am Management Review teil und absolviert die für Leitungsorgane vorgesehene Schulung.

4.2 Informationssicherheitsbeauftragter (ISB)

Zum Informationssicherheitsbeauftragten ist **DI Markus Pichler** bestellt, Stellvertreter ist **Stefan Wurm, BSc**. Der ISB berichtet direkt an die Geschäftsführung und ist in Fragen der Informationssicherheit weisungsfrei. Er koordiniert das ISMS, die Risikoanalyse, interne Audits und die Behandlung von Sicherheitsvorfällen und ist erste Ansprechperson für das Group Security Office.

4.3 Informationssicherheitsteam (IST)

Das IST besteht aus dem ISB, der IT-Leitung (Ing. Sabine Hofbauer), der Datenschutzbeauftragten (Mag.a Julia Wimmer), je einer Vertretung aus Lagerlogistik und Fuhrpark/Telematik sowie den Standortkoordinatoren für Deutschland und Tschechien. Das IST tagt monatlich.

4.4 Systemowner

Für jedes wesentliche IT-System ist ein Systemowner benannt (z. B. LVS: Leiter Lagerlogistik; TMS: Leiterin Disposition). Systemowner verantworten Schutzbedarfsfeststellung, Berechtigungskonzept und fachliche Freigaben ihres Systems.

4.5 Führungskräfte und Mitarbeitende

Führungskräfte setzen die Vorgaben in ihrem Bereich um und haben Vorbildfunktion. Alle Mitarbeitenden sind verpflichtet, die Richtlinien einzuhalten und Sicherheitsvorfälle oder Schwachstellen unverzüglich zu melden.

5 Grundsätze

5.1 Klassifizierung von Informationen

Informationen werden in vier Stufen klassifiziert: ÖFFENTLICH, INTERN, VERTRAULICH und STRENG VERTRAULICH (entspricht Public / Internal / Confidential / Strictly Confidential der Konzernvorgaben). Kunden- und Sendungsdaten sind mindestens als VERTRAULICH einzustufen.

5.2 Risikomanagement

Der ISB führt jährlich sowie anlassbezogen bei wesentlichen Änderungen eine Risikoanalyse durch. Risiken oberhalb der Risikoakzeptanzschwelle werden der Geschäftsführung zur Entscheidung vorgelegt.

5.3 Zugriffsrechte

Zugriffsrechte werden nach den Prinzipien „Need-to-know“ und „Least Privilege“ vergeben. Zugriffsrechte werden einmal jährlich durch die zuständigen Führungskräfte rezertifiziert. Einzelheiten regelt die Richtlinie Zugriffsmanagement.

5.4 Business Continuity

Für kritische Systeme und Prozesse werden Notfallpläne erstellt, mindestens jährlich geübt und nach jeder Übung bzw. jedem Ernstfall aktualisiert.

5.5 Lieferanten und Dienstleister

Sicherheitsanforderungen an Lieferanten, Dienstleister und Subunternehmer werden vor Vertragsabschluss festgelegt und vertraglich vereinbart.

5.6 Sensibilisierung

Alle Mitarbeitenden erhalten bei Eintritt sowie regelmäßig danach Schulungen zur Informationssicherheit (siehe Awareness-Programm).

5.7 Behandlung von Sicherheitsvorfällen

Sicherheitsvorfälle sind unverzüglich zu melden und nach der Richtlinie Incident Response zu behandeln.

6 Ausnahmen und Verstöße

6.1 Ausnahmen

Ausnahmen von lokalen Richtlinien sind schriftlich beim ISB zu beantragen. Nach Risikobewertung entscheidet die Geschäftsführung; Ausnahmen sind auf höchstens 12 Monate befristet und werden im Ausnahmeregister geführt. Ausnahmen von Konzernstandards genehmigt ausschließlich das Group Security Office (Group CISO).

6.2 Verstöße

Verstöße gegen diese Leitlinie oder nachgeordnete Richtlinien können arbeitsrechtliche bzw. vertragliche Konsequenzen haben.

7 Überprüfung und Weiterentwicklung

Der ISB überprüft diese Leitlinie jährlich auf Aktualität und Angemessenheit. Das Management Review findet einmal jährlich im ersten Quartal statt; die Ergebnisse fließen in die Weiterentwicklung des ISMS ein.

8 Inkrafttreten

Diese Leitlinie tritt am 01.03.2025 in Kraft und ersetzt die Version 3.1.

Linz, am 15.02.2025

Mag. Bernhard Strasser Geschäftsführer	Ing. Petra Lindner Geschäftsführerin